



目录

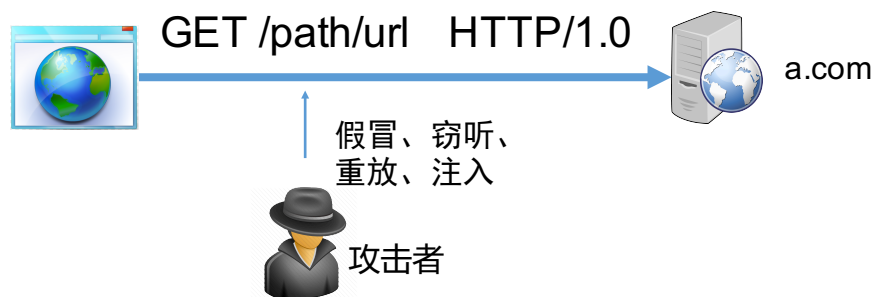
- ▶ HTTP/HTTPS协议及中间节点
- 透明缓存的污染攻击
- 绕过加密协议HTTPS的攻击
- 针对CDN的拒绝服务攻击
- 结论

ZERO TRUST SECURITY

HTTP最初的设计与应用场景



- HTTP设计之初是端到端的协议
- 网络只是传输转发的透明管道
- 没有身份认证、保密性、完整性保护
- 网络攻击者：假冒、窃听、注入、重放

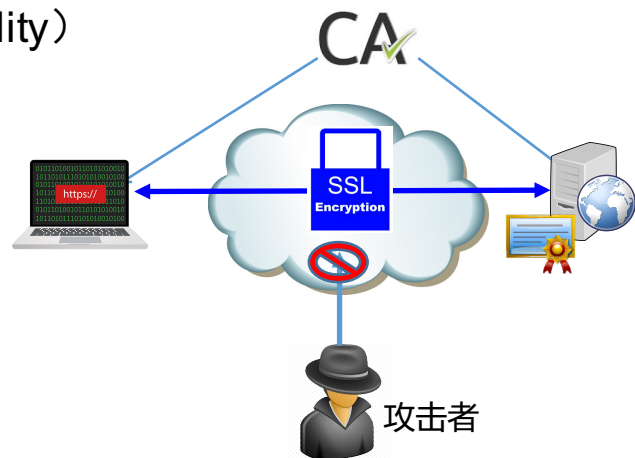


ZERO TRUST SECURITY

HTTPS：认证、加密、完整性



- HTTPS: HTTP/SSL 或HTTP/TLS
- Web 服务器的标识与认证
- 内容的保密性（Confidentiality）
- 内容的完整性（Integrity）

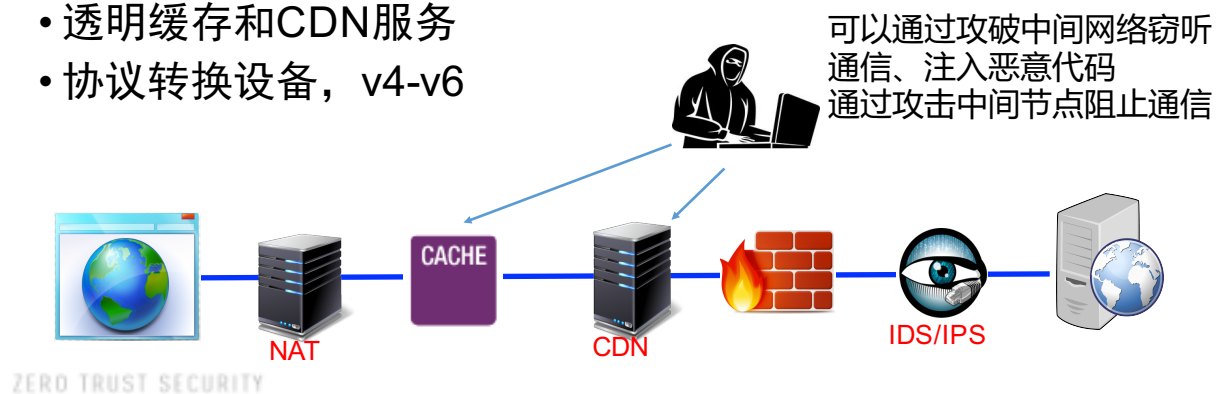


ZERO TRUST SECURITY

中间盒子的兴起



- 与HTTPS同步发展起来的还有各种中间盒子
- HTTP 客户端代理、防病毒软件、广告软件等
- 服务器端代理、负载均衡设备
- 透明缓存和CDN服务
- 协议转换设备，v4-v6



目录



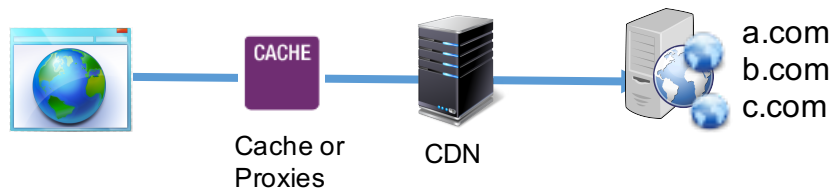
- HTTP/HTTPS协议及中间节点
- ▶ 透明缓存的污染攻击
- 绕过加密协议HTTPS的攻击
- 针对CDN的拒绝服务攻击
- 结论

ZERO TRUST SECURITY

标准的歧义

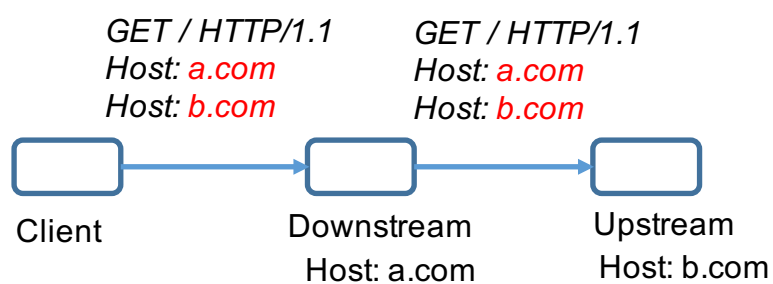


GET **nonhttp://a.com**/path/url HTTP/1.1
 Host: **b.com**
 Host: **c.com**



ZERO TRUST SECURITY

多个 Host headers



HTTP standard(HTTP/1.1)

- RFC 2616(superseded standard), implicitly requires rejection.
- RFC 7230(latest standard), explicitly requires rejection.

ZERO TRUST SECURITY

8

各种主流的HTTP实现



实现		处理方式	实现	处理方式	实现	处理方式		
Server	Apache	Concatenate	CDN	Akamai	First	Firewall	Bitdefender	First
	IIS	Reject		Alibaba	First		ESET	Last
	Nginx	First		Azure	Reject		Huawei	First
	Tomcat	First		CloudFlare	First		Kaspersky	First
Transparent cache	ATS	First		CloudFront	First		OS X	Concatenate
	Squid	First		Fastly	Reject		PAN	First
Reverse Proxy	Nginx	First		Level 3	First		Windows	First
	Varnish	Reject		Tencent	Last			

- 主流的HTTP实现各不相同
- 几乎所有的实现都不遵守 RFC7230

ZERO TRUST SECURITY

9

标准规定绝对路径优先，然而现实中...



HTTP 标准规定：

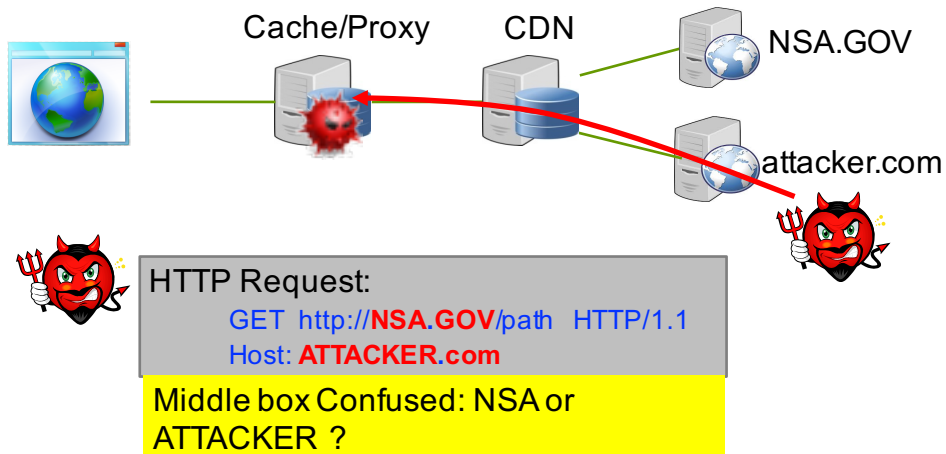
	优先选择	不认识的协议
RFC 2616	Absolute-URI	Not specified
RFC 7230	Absolute-URI	Not specified

- 主流的CDN实现中，大多数实现遵守了RFC
- 最大的CDN厂商Akamai不遵守，但世界35%流量

ZERO TRUST SECURITY

10

缓存污染攻击(CCS 2016)



ZERO TRUST SECURITY

如何攻破 NSA.GOV



ZERO

12

可能被攻击的场景（上下游组合）



Downstream \ Upstream		Reverse Proxy							CDN							Server						
		Apache	IIS	Lighttpd	LiteSpeed	Nginx	Squid	Varnish	Akamai	Alibaba	Azure	CloudFlare	CloudFront	Fastly	Level3	Tencent	Apache	IIS	Lighttpd	LiteSpeed	Nginx	Tomcat
Transparent Cache	ATS				✓		✓		✓						✓							
	Squid						✓		✓						✓							
Forward Proxy	Apache														✓							
	Squid						✓		✓						✓							
Reverse Proxy	Apache																					
	Lighttpd				✓	✓													✓	✓	✓	✓
	LiteSpeed	✓		✓		✓		✓									✓		✓		✓	✓
	Squid						✓												✓	✓	✓	✓
	Varnish		✓	✓	✓	✓												✓	✓	✓	✓	✓
CDN	Akamai						✓															
	Alibaba				✓		✓		✓										✓	✓	✓	✓
	CloudFlare	✓	✓	✓	✓	✓	✓	✓	✓	✓	—	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
	CloudFront											—			✓							
	Fastly		✓	✓	✓	✓			✓	✓		✓	—	✓	✓	✓			✓	✓	✓	✓
Firewall	Bitdefender	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
	ESET	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
	Huawei	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
	Kaspersky	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
	OS X	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓		✓	✓	✓	✓	✓	✓	✓	✓	✓
	PAN	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
	Windows	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓

ZERO TRUST SECURITY

202 different combinations that could be exploited.

13

影响到的产品/系统



Windows 8.1 Tencent



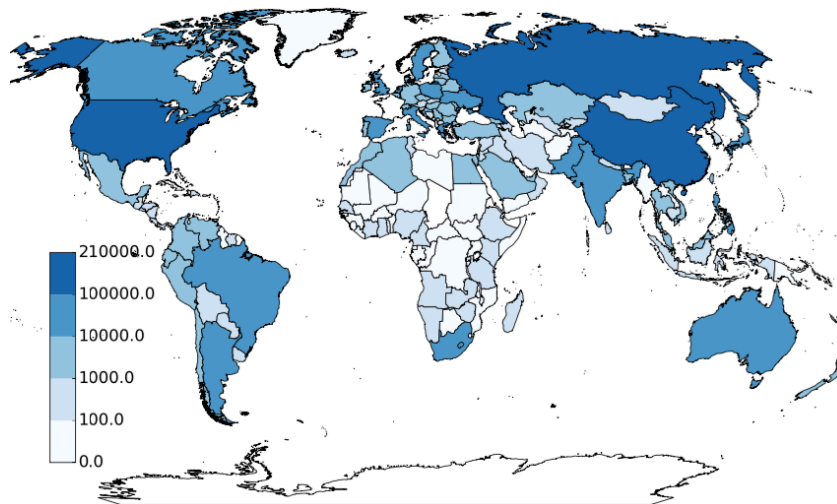
traffic server™ Alibaba.com



ZERO TRUST SECURITY

14

98% 缓存服务器可能受到攻击



- 通过购买广告，把Flash 代码展示在世界各地的浏览器上

ZERO TRUST SECURITY

15

目录



- HTTP/HTTPS协议及中间节点
- 透明缓存的污染攻击
- ▶ • 绕过加密协议HTTPS的攻击
- 针对CDN的拒绝服务攻击
- 结论

ZERO TRUST SECURITY

CDN已成为互联网重要的基础设施

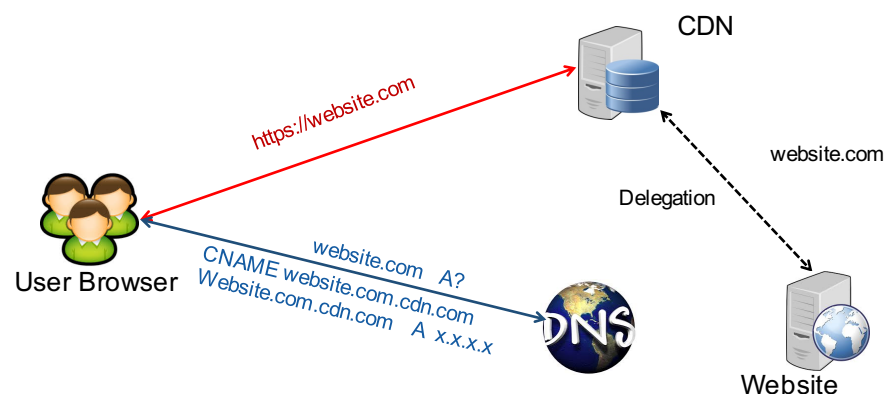


- 全球，根据最大的CDN厂商 Akamai统计：
 - 全球Web流量的**15-30%**
 - 每秒**30T**
 - 每天**2万亿**次交互
 - **200,000**服务器、**100**国家
- 中国，根据《工信部CDN白皮书2014》统计
 - Alexa排名前100: **91%**,
 - Alexa排名前546: **72.5%**



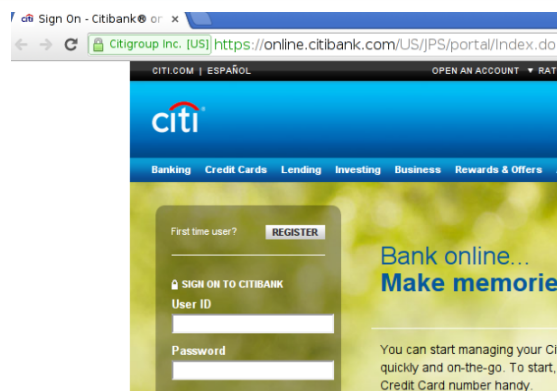
ZERO TRUST SECURITY

工作原理：基于域名的重定向



ZERO TRUST SECURITY

银行也在用CDN



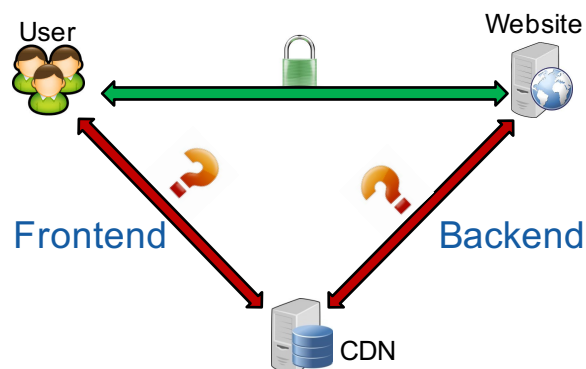
```
CNAME  online.citibank.com.edgekey.net.  
IN CNAME e5035.b.akamaiedge.net.  
A      184.28.156.106
```

ZERO TRUST SECURITY

When HTTPS Meets CDN

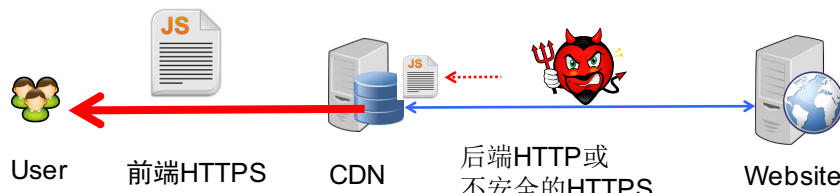


- 从两方通信变成了三方通信
- 我们可以看到前端使用了HTTPS，但是后端呢？



ZERO TRUST SECURITY

HTTPS in CDN的安全问题(Security&Privacy14)



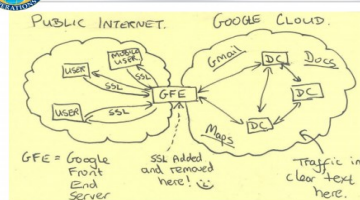
CDN Provider	后端协议
CDN77	HTTP
CDN.NET	HTTP
CloudFlare	HTTPS, not validate certificate
Incapsula	HTTPS, not validate certificate
CloudFront	HTTPS, not validate CN

ZERO TRUST SECURITY

TOP SECRET//SI//NOFORN



Current Efforts - Google



TOP SECRET//SI//NOFORN

Apple & Akamai 受攻击事件,2014/4/15



- 动态网页
- 手机版
- 免费下载
- 技术支持反馈
- 用户指南
- 常见问题
- 关于动态网页

http://www.google.com/ 浏览任意网站

免费下载 (安全认证)

动态网页系列软件

自由门7.42专业版 (2013年11月8日) 历史最久, 使用人数最多。	下载exe 下载zip
自由门7.42专业版 (2013年11月8日) 用户界面为专业人士最爱。	下载exe 下载zip
自由门7.42限制版 (2013年11月8日) 缺省只能上少数几个网站, 进一步增强安全性。	下载exe 下载zip

ZERO TRUST SECURITY

Today, we came across an incident on "images.apple.com", which is hosted by Akamai:

When we visit the URL "http://images.apple.com/global/scripts/apple_core.js" in CERNET in China, we will get a fake Javascript file; however, when we visit the same URL using HTTPS, we will get the true file.

The DNS resolution of "images.apple.com" in CERNET is as follows:

```
images.apple.com. 2992 IN CNAME images.apple.com.edgesuite.net.
images.apple.com.edgesuite.net. 8473 IN CNAME images.apple.com.edgesuite.net.globalredir.akadns.net.
images.apple.com.edgesuite.net.globalredir.akadns.net. 2992 IN CNAME a199.cn.w.ti88.net.
a199.cn.w.ti88.net. 20 IN A 58.205.224.231
a199.cn.w.ti88.net. 20 IN A 58.205.224.234
```

Several possible reasons may result in this incident, such as MITM attack, the two servers are compromised and etc. However, from outside, we could not figure out what exactly is happening. So we turn to you for help. Please let us know if you need more information or if you have any idea about this incident. Thank you.

Besides, Chinanetcenter, a CDN provider in China, seems involved in this case as well. So we are curious about the cooperation between Akamai and Chinanetcenter and how it works. Could you introduce more details on this for us?

We will really appreciate your help and look forward to your reply.

Thank you.

From: [redacted]@akamai.com> 1:49 AM (7 hours ago) ☆ ↶ ↷

To: [redacted]

Hello Jijun

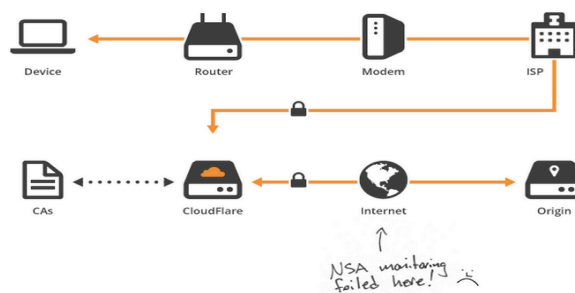
Thanks for pointing this out! Sorry for the long time it took me to respond. Yes, it appears that this was due to a MITM attack on CERNET. One of our proxy servers obtained the fake file in response to the request issued. Using HTTPS we're able to authenticate the origin and this type of attack can't happen. If you ever encounter something suspicious again, please let us know.

Thanks

来自工业界的反馈

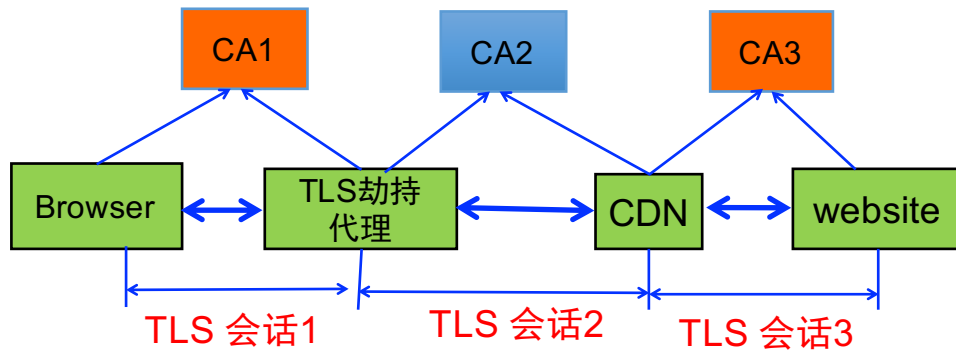
- Akamai/ CloudFlare/Amazon等积极反馈
- CloudFlare 在1个月内推出Strict SSL 服务

CloudFlare full SSL (strict) — front-end over TLS, back-end over TLS (validated)



<http://blog.cloudflare.com/introducing-strict-ssl-protecting-against-a-man-in-the-middle-attack-on-origin-traffic>

TLS还有很多中间人

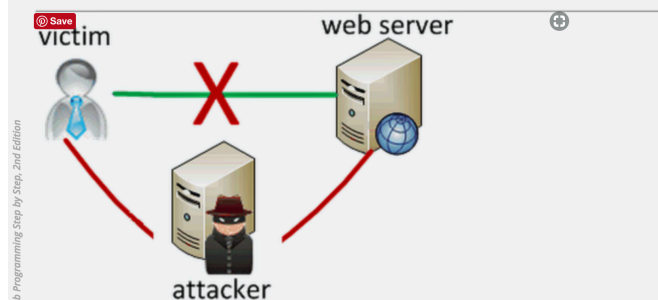


ZERO TRUST SECURITY

Lenovo PCs ship with man-in-the-middle adware that breaks HTTPS connections [Updated]

Superfish may make it trivial for attackers to spoof any HTTPS website.

DAN GOODIN - 2/20/2015, 12:36 AM



ZERO

目录



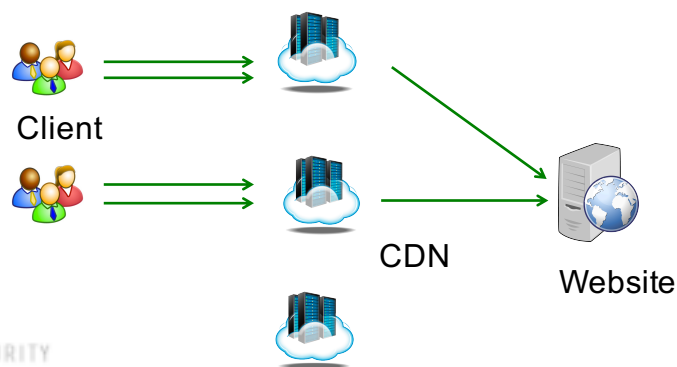
- HTTP/HTTPS协议及中间节点
- 透明缓存的污染攻击
- 绕过加密协议HTTPS的攻击
- 针对CDN的拒绝服务攻击
- 结论

ZERO TRUST SECURITY

CDN的功能



- 分担负载、降低延迟
- 安全过滤(WAF), 提高可用性(anti-DDoS)



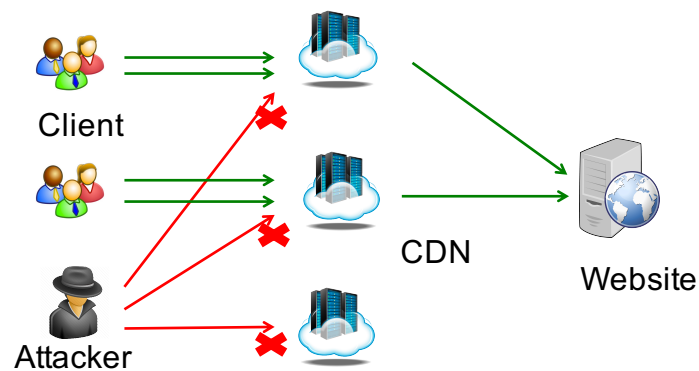
ZERO TRUST SECURITY

28

CDN的功能



- 分担负载、降低延迟
- 安全过滤(WAF), 提高可用性(anti-DDoS)

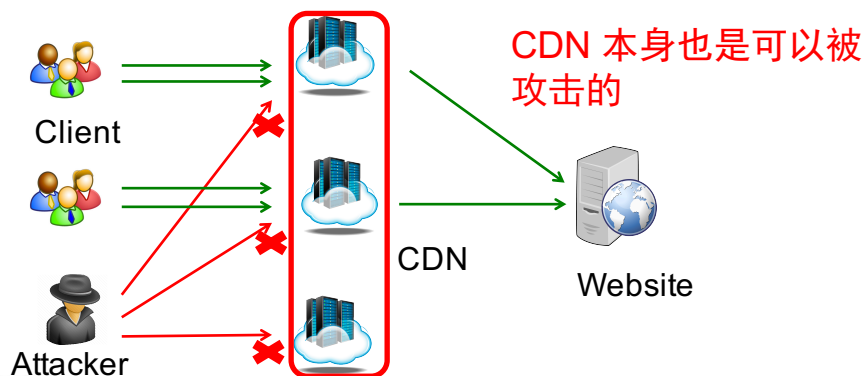


29

CDN的功能

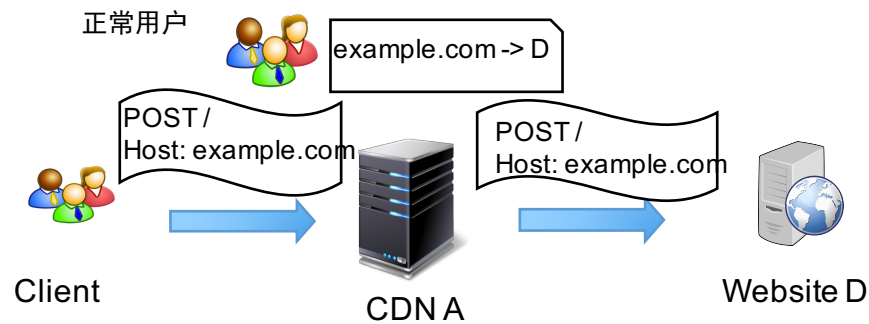


- 分担负载、降低延迟
- 安全过滤(WAF), 提高可用性(anti-DDoS)



30

正常的CDN转发流程

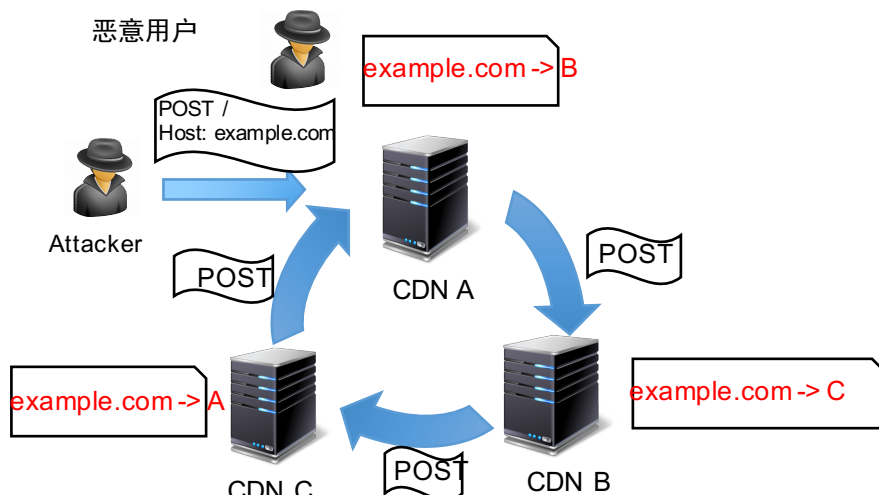


用户控制着CDN转发规则

ZERO TRUST SECURITY

31

转发循环攻击的概念



- Malicious customers can manipulate forwarding rules to create loop
- Amplification -> consume resource -> potentially DoS

ZERO TRUST SECURITY

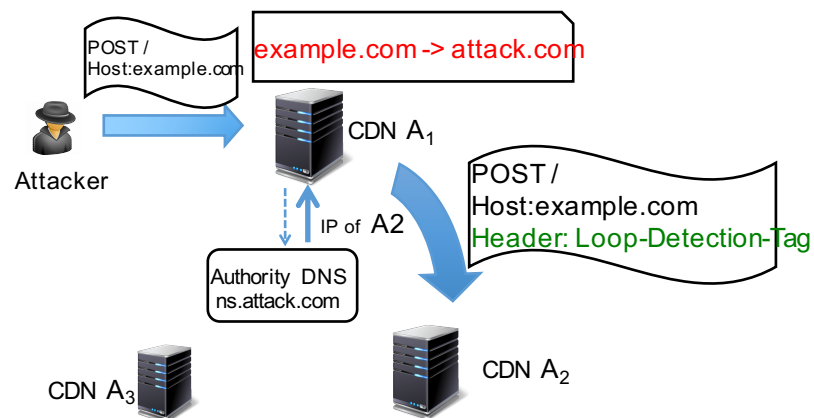
32

受到影响的CDN厂商



ZERO TRUST SECURITY

CDN内部采用的循环检测机制

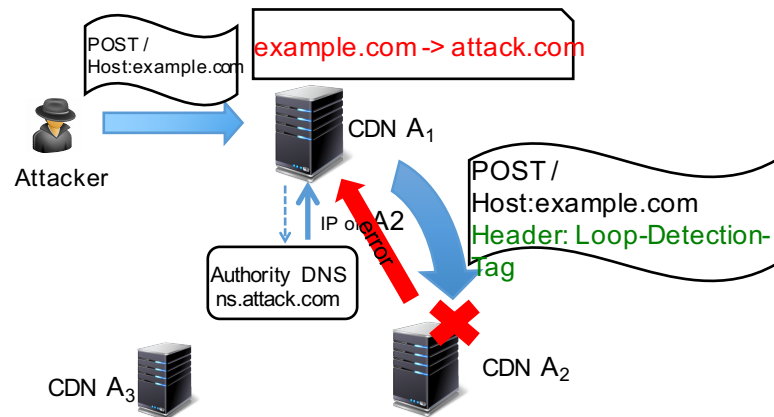


Current Defenses

Use headers to tag processed requests

ZERO TRUST

CDN内部采用的循环检测机制



Current Defenses

Use headers to tag processed requests

ZERO TRUST

不同厂商用于循环检测的Header是不一样的



CDN Provider	Loop Detection Header	CDN Provider	Loop Detection Header
Akamai	Akamai-Origin-Hop	CloudFlare	X-Forwarded-For CF-Connecting-IP
Alibaba	Via	CloudFront	Via
Azure(China)		Fastly	Fastly-FF
Baidu	X-Forwarded-For CF-Connecting-IP	Incapsula	Incap-Proxy-ID
CDN77		KeyCDN	
CDNlion		Level3	Via
CDN.net		MaxCDN	
CDNsun		Tencent	X-Daa-Tunnel

ZERO TRUST SE detection

如何绕过CDN的循环检测



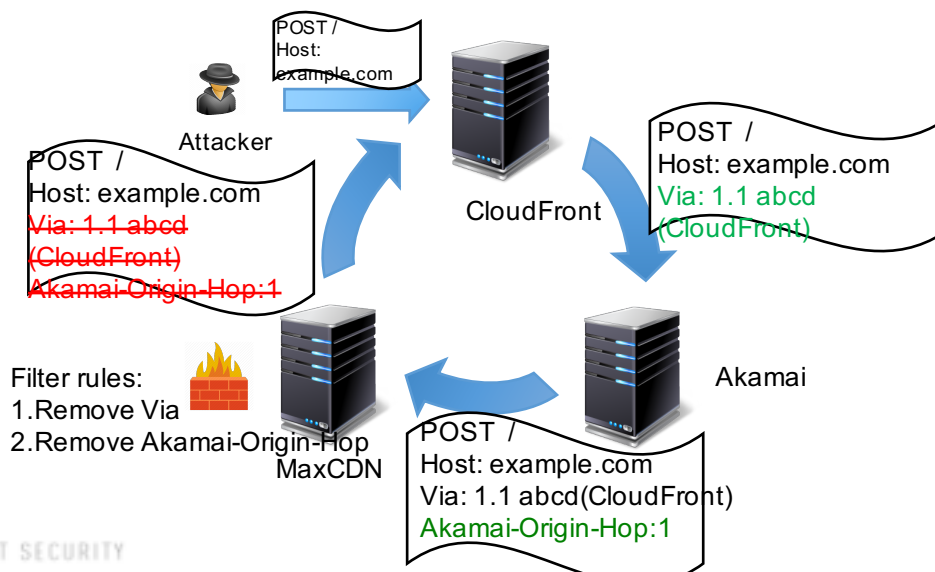
- Chain loop-aware CDNs to other CDNs that can be abused to **disrupt** loop-detection headers
- Abusive features provided by CDNs:

CDN Provider	Reset	Filter
CDN77	Via	
CDNlion	Via	
CDN.net	Via	
CDNsun	Via	
Fastly		No-self-defined
MaxCDN		Any

ZERO TRUST SECURITY

37

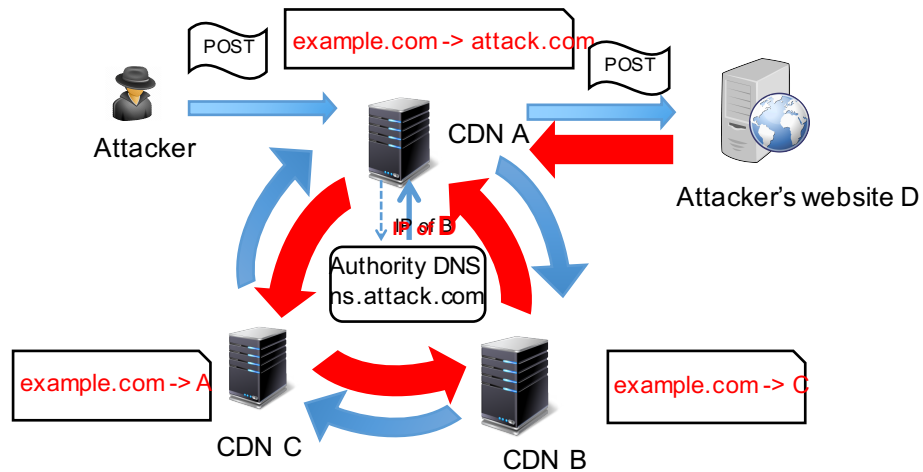
跨多个CDN厂商的循环



ZERO TRUST SECURITY

38

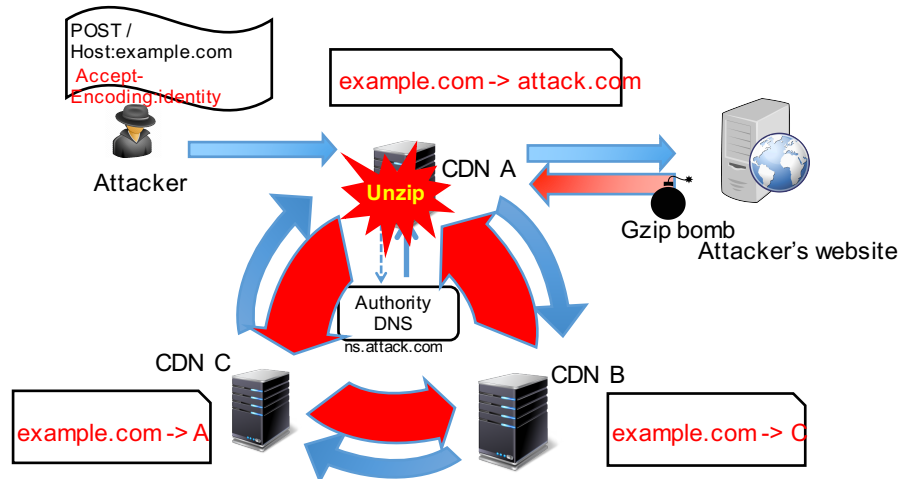
大坝攻击(Dam Flooding): streaming 中增加响应



ZERO TRUST SECURITY

39

增加gzip炸弹增强Streaming的效果



- 3 CDNs can be used to uncompress gzip bombs
- Total Amplification Factor = Loop Amplification * Gzip Bomb Amplification (~ 1000)

ZERO TRUST SECURITY

40




我们相信你们所指出的攻击是对CDN和整个Internet的
严重威胁，
你们能否协调不同CDN的交流和沟通

AMIR.

On Mon, Oct 26, 2015 at 2:34 PM, Amir Khakpour <amir.khakpour@verizondigitalmedia.com> wrote:
 Hi Haixin/Jianjun,

My name is Amir, and I work in Verizon Digital Media Services (formerly known as Bell Media). As you might know, we are one of the major CDNs in the world.

One of our clients shared your paper with us to assess if we are vulnerable to loop-detection attacks you described in your paper.

First of all, we wanted to congratulate you on the great work and nicely written and technically detailed paper. We believe the attacks you mentioned are valid and can be a great danger to CDNs and Internet in general. This is indeed something we take very seriously.

Secondly, we agree with you that the most effective way to defend such attack is what you have called "Unifying and standardizing loop-detection header" in the paper. We wonder if you are willing to coordinate the effort of communicating with different CDNs to disallow their customers from tampering with and/or removing "via", "forwarded", and "X-forwarded-for" headers. This would indeed help CDNs to avoid multi-CDN and Denial of Service flooding attacks. This can be easily verifiable by a third-party such as you (or academia, in general) as a follow-up work.

Please let us know if any help on your side is needed.

Also, if you are willing to chat about this matter, please let us know your convenient time and we can schedule a meeting.

Thanks,

ZERO TRUST SECURITY
41




总结与思考

- 由于中间盒子的存在，增大了攻击面
- 互联网标准实现问题
 - 兼容性和安全性的矛盾
 - IETF标准的制定和实施过程：并非强制
 - 单个厂商IETF标准的实现：non-compliant
 - 不同厂商之间标准实现的不一致：inconsistent
- 没有协调的系统，可能产生很多安全问题
 - 我们不知道自己已经在火山口上
- 各厂商之间如何建立协调机制，有待社会各方面的努力

ZERO TRUST SECURITY
42

谢谢

段海新，清华-360企业安全集团联合研究中心

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing, China
[原“中国互联网安全大会”]